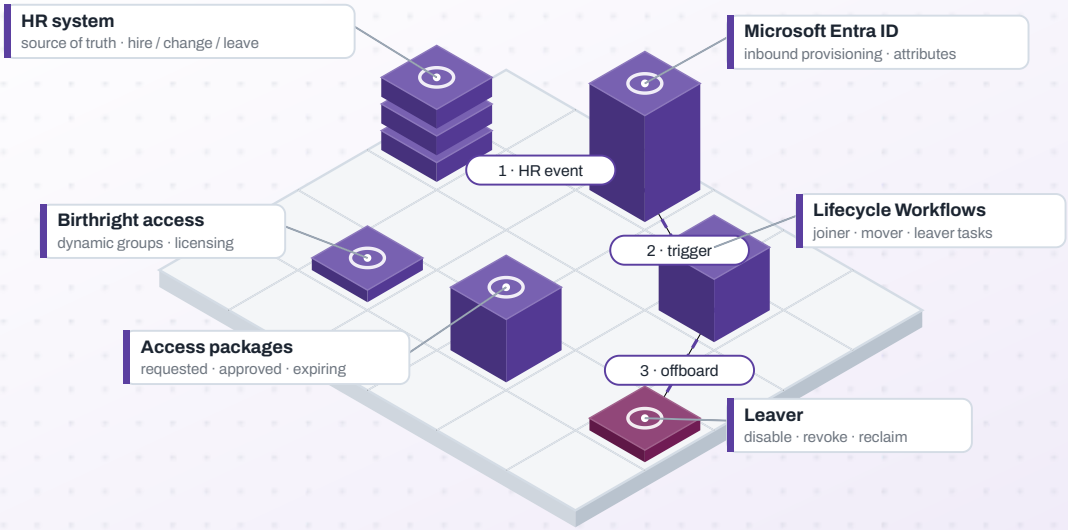
STANDARD OPERATING PROCEDURE · FIELD GUIDE SERIES

SOP-ID-002

Managing the Joiner-Mover-Leaver Account Lifecycle in Microsoft Entra ID

Drive every account from the HR record: provision on hire with birthright access and a Temporary Access Pass, move access when the job changes, and on departure disable, revoke, recover data and reclaim licenses on a fixed timeline, with Lifecycle Workflows, entitlement management and a quarterly stale-account review as evidence.

Identity & Access | Identity Governance | Account Lifecycle



DOCUMENT ID	SOP-ID-002
VERSION	1.0
EFFECTIVE	October 2026
AUDIENCE	Identity and M365 administrators, service desk leads, HR systems owners, auditors (Chapter 7)
AUTHOR	Richmond Dieujuste, Principal Consultant

Contents

1. Concepts You Need First 3
1.1 The three events 4
1.2 HR as the source of truth 4
1.3 Attributes that drive the lifecycle 5
1.4 Birthright access versus requested access 6
1.5 Choosing a method 6

2. Access, Prerequisites and Planning 8
2.1 Level of access required 8
2.2 Licensing 8
2.3 Prerequisites checklist 8
2.4 Retention decisions 9
2.5 Risk and planning notes 9

3. Birthright Access: Dynamic Groups and Licensing 10

4. Method A · Joiner, Mover and Leaver by Hand 12
4.1 Joiner 12
4.2 Mover 13
4.3 Leaver 13

5. Method B · Lifecycle Workflows 15
5.1 The workflow set 15
5.2 Graph PowerShell for workflow evidence 17

6. Method C · Graph PowerShell for Urgent Leavers and Reviews 18
6.1 Urgent leaver 18
6.2 Quarterly stale and orphaned account review 19

7. Verification, Rollback and Troubleshooting 21
7.1 Verification checklist 21
7.2 Rollback 22
7.3 Troubleshooting 22

8. Summary, Glossary and Review 23
8.1 Chapter summary 23
8.2 Glossary 23
8.3 Framework references 24

LEARNING OBJECTIVES

After working through this procedure you will be able to:

- Explain why HR must be the source of truth for identity and which attributes drive joiner, mover and leaver events.
- Separate birthright access (dynamic groups, group-based licensing) from requested access (access packages with expiry).
- Build joiner, mover and leaver Lifecycle Workflows, and run the same leaver actions by hand or from Graph PowerShell.
- Execute a same-day leaver: disable, revoke sessions, remove access, preserve mail and OneDrive, retire devices, reclaim licenses.
- Run the quarterly stale and orphaned account review from signInActivity and close it with evidence.

Time	Difficulty	Minimum access	Risk
Joiner 30 min · leaver 20 min · review 2 h/quarter	Intermediate	User Administrator + Lifecycle Workflows Administrator	Moderate: leaver steps cut access immediately

CHAPTER 1

Concepts You Need First

Every account in the tenant should exist because a person (or a system with an owner) needs it today, and should have only the access that person needs today. **Joiner-Mover-Leaver** (JML) is the name for the three moments when that changes: someone arrives, someone changes role, someone leaves. Account management controls in every framework, from NIST AC-2 to SOX IT general controls, are tested at exactly those three moments.

KEY CONCEPT · THE ACCOUNT FOLLOWS THE PERSON, NOT THE TICKET

When accounts are created from service desk tickets, they drift: a ticket is late, a mover keeps the old team's access, a leaver's manager forgets to tell IT. When accounts are driven by the HR record, the hire date, job change and leave date arrive as data, and the identity system acts on them. Tickets become the *evidence* of what happened, not the trigger.

1.1 The three events

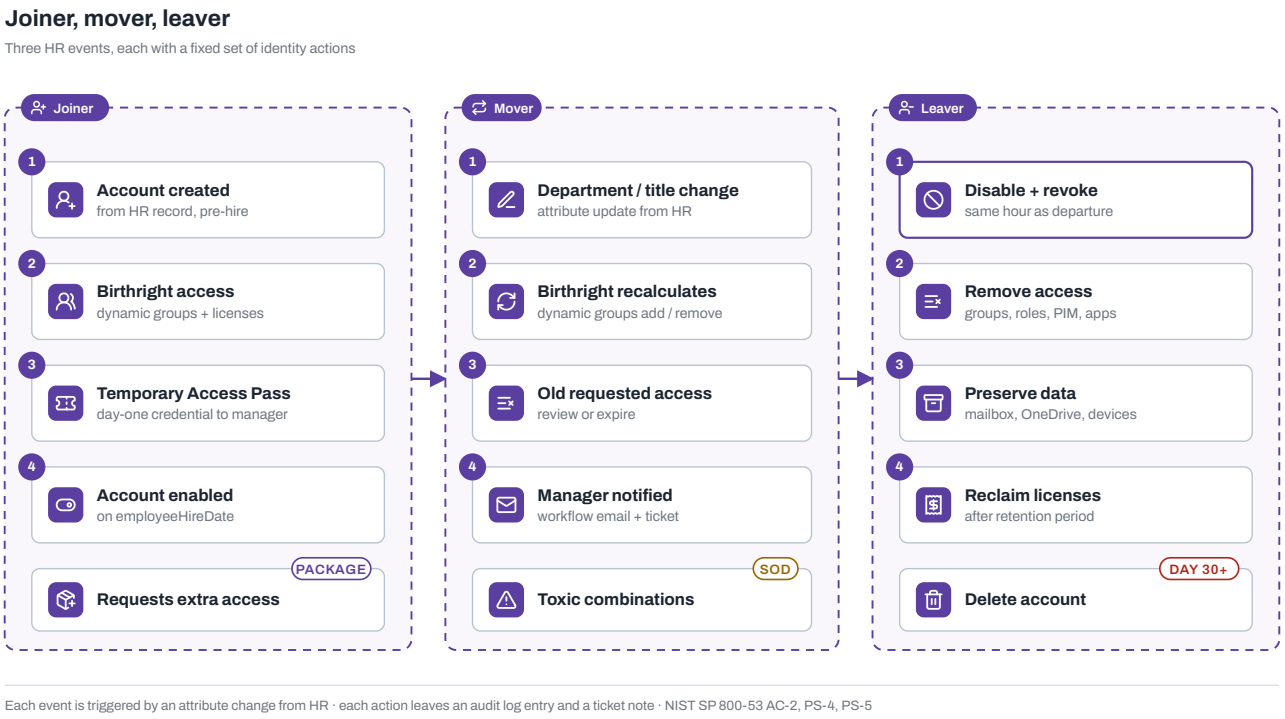


Figure 1. The account lifecycle. The numbered actions inside each event are the checklist this SOP builds, automates and evidences.

1.2 HR as the source of truth

There are three supported ways for HR data to reach Entra ID. The choice depends on where accounts are mastered today, not on preference: if users still sign in to on-premises Active Directory, AD stays the identity source and HR feeds AD; if the organization is cloud-only, HR feeds Entra ID directly.

Pattern	How it works	Use when
HR-driven inbound provisioning	Microsoft-built connectors (Workday, SuccessFactors) create and update users in AD or Entra ID on a schedule	A supported cloud HR system is in place
API-driven inbound provisioning	Any HR system (or a CSV export) posts SCIM bulk requests to the provisioning API; Entra ID or AD is updated	HR is on-premises, custom or unsupported; you control the export
AD-mastered with sync	Accounts are created in AD (by HR feed or script) and reach Entra ID via Entra Connect Sync or Cloud Sync	Hybrid estate with on-premises apps and domain-joined devices

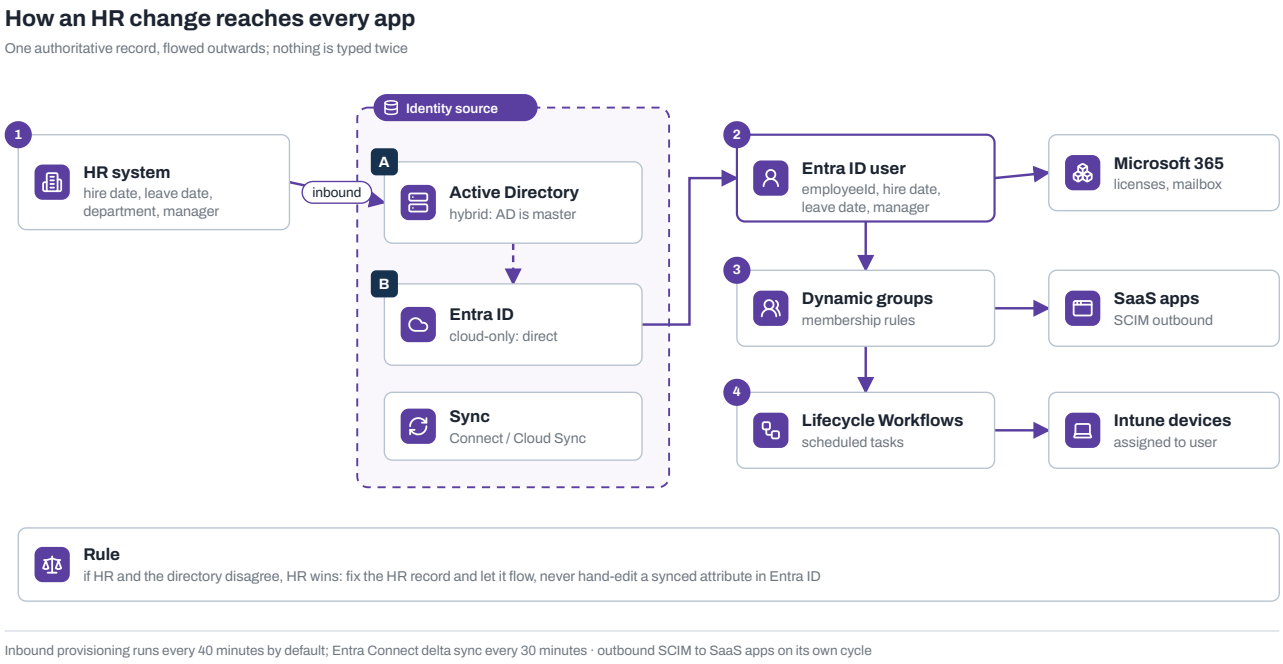


Figure 2. Data flow from HR to applications. Pattern A (hybrid) and pattern B (cloud-only) differ only in where the account is mastered.

1.3 Attributes that drive the lifecycle

Lifecycle automation is only as good as the attributes it reads. Agree these with HR before building anything, and treat a blank or wrong value as a data-quality defect with an owner.

Attribute	Purpose	Standard
`employeeId`	Joins the HR record to the account; never reused	HR employee number, immutable
`employeeHireDate`	Triggers joiner workflows (pre-hire and day-one)	UTC date-time from HR
`employeeLeaveDateTime`	Triggers leaver workflows (pre, on and post departure)	UTC date-time; written by provisioning or Graph
`department`, `jobTitle`, `companyName`	Dynamic group rules; mover detection	HR code lists, not free text
`manager`	Approvals, TAP delivery, OneDrive access on leave	Reference to the manager's account
`employeeType`	Separates employees, contractors, interns	Fixed list: *Employee*, *Contractor*, *Intern*
`userPrincipalName`, `mail`	Sign-in name and address	`first.last@contoso.com`; collisions add a digit

WATCH OUT · WRITING THE LEAVE DATE NEEDS ITS OWN PERMISSION

`employeeLeaveDateTime` cannot be set by User Administrator alone. Graph needs `User-LifeCycleInfo.ReadWrite.All` (or the Lifecycle Workflows Administrator role for interactive use). If leaver workflows never fire, check this attribute first.

1.4 Birthright access versus requested access

Access is granted two ways. **Birthright** access is what every person in a role gets automatically: email, Teams, the department SharePoint site, the standard license. **Requested** access is anything beyond that: a finance application, an admin role, a project site. Birthright access is driven by attributes and disappears when the attribute changes. Requested access is approved, time-limited and reviewed.

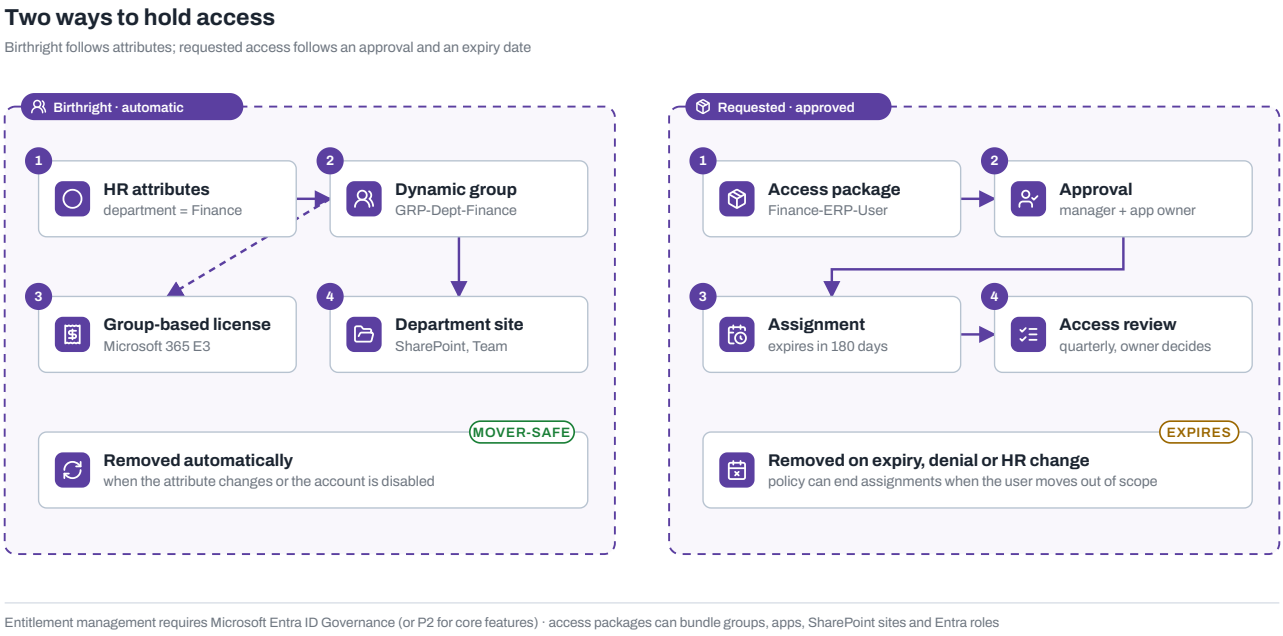


Figure 3. Birthright access needs no ticket; requested access needs an approver and an end date. Admin roles are always requested, never birthright.

1.5 Choosing a method

Method	Best for	Evidence produced
A · Entra admin center (manual)	Small tenants; exceptions; learning the steps	Audit log entries, ticket notes, screenshots
B · Lifecycle Workflows	Every scheduled joiner and leaver once attributes are reliable	Workflow run history per user and task
C · Graph PowerShell	Urgent (hostile) leavers; bulk actions; the quarterly review	Script transcript and CSV output attached to the ticket

GOOD PRACTICE · AUTOMATE THE NORMAL, SCRIPT THE URGENT

Lifecycle Workflows handle the scheduled cases on time, every time. A termination for cause cannot wait for the next scheduled run: it uses the Method C script, run by a person, in the same hour, with the HR contact on the call.

CHAPTER 2

Access, Prerequisites and Planning

2.1 Level of access required

Task	Minimum role	Notes
Create, update, disable users; revoke sessions; reset passwords	User Administrator	Cannot act on administrators; use Privileged Authentication Administrator for those.
Create and run Lifecycle Workflows	Lifecycle Workflows Administrator	Requires Microsoft Entra ID Governance licensing for users in scope.
Catalogs, access packages, access reviews	Identity Governance Administrator	Catalog owners can be delegated per business area.
Dynamic groups, group-based licensing	Groups Administrator + License Administrator	Dynamic membership needs Entra ID P1.
Issue a Temporary Access Pass	Authentication Administrator	Privileged Authentication Administrator for admin accounts.
Convert mailbox, litigation hold	Exchange Administrator	Hold also possible from Purview by eDiscovery / compliance roles.
Retire or wipe devices	Intune Administrator	Wipe protected by multi-admin approval (SOP-EM-003).
Disable account in on-premises AD	Delegated OU rights (Account Operators-equivalent)	Hybrid only; Entra ID cannot disable a synced account authoritatively.

2.2 Licensing

Dynamic groups, group-based licensing and sign-in activity reporting require **Microsoft Entra ID P1**. Lifecycle Workflows, and the full entitlement-management feature set (custom extensions, sponsor policies, guest conversion), require **Microsoft Entra ID Governance** for the users in scope. Access reviews and core access packages are also available with **Entra ID P2**. Everything in Method A and Method C works with P1.

2.3 Prerequisites checklist

- [ ] Written JML standard agreed with HR: who triggers each event, notice periods, and the same-day leaver definition.
- [ ] HR feed in place (inbound provisioning or AD feed) and populating `employeeId`, `employeeHireDate`, `department`, `manager`.

- [ ] `employeeLeaveDateTime` populated by the HR feed, or a documented manual step to write it when HR confirms a leave date.
- [ ] Naming and attribute standard published (Chapter 1.3) and checked against a sample export of 50 accounts.
- [ ] Dynamic groups and group-based license assignments built and validated (Chapter 3).
- [ ] Authentication methods policy enables Temporary Access Pass for the *All users* or *New starters* group.
- [ ] Mailbox and OneDrive retention decisions recorded with Legal / Records (Chapter 2.4).
- [ ] ServiceNow catalog items for *New hire*, *Role change* and *Termination* include the fields this SOP needs (leave date and time, manager, urgent flag).
- [ ] Sign-in and audit logs exported to a Log Analytics workspace and retained at least 90 days.

2.4 Retention decisions

Data	Default behaviour	Baseline choice
Mailbox	Deleted with the user license; recoverable 30 days after user deletion	Convert to shared mailbox (no license under 50 GB); litigation hold for staff in scope of legal holds
OneDrive	Manager gets access; deleted after the OneDrive retention period (30 days default)	Retention period 365 days in SharePoint admin center; manager moves needed files to a team site within 30 days
Teams chats	Retained per Purview retention policy	Governed by the tenant retention policy, not by this SOP
Devices	Remain enrolled and assigned to the disabled user	Retire corporate data within 1 business day; wipe on return for reissue
Account	Soft-deleted for 30 days, then permanently removed	Disable on day 0; delete on day 30 after data steps are evidenced

2.5 Risk and planning notes

Action	Risk	Notes
Report stale accounts from signInActivity	READ-ONLY	Always first in the quarterly review.
Issue a Temporary Access Pass	LOW	One-time use, 8-hour lifetime, delivered to the manager, not emailed to the user.
Change a dynamic group rule	MODERATE	A typo can remove access from a whole department. Validate rules before saving.
Disable account and revoke sessions	MODERATE	Immediate loss of access; confirm identity and date with HR first.

Action	Risk	Notes
Remove licenses	HIGH	Starts the mailbox deletion clock if the mailbox was not converted to shared first.
Delete the account	HIGH	Recoverable for 30 days only; after that, mailbox and OneDrive links are lost.

CHAPTER 3

Birthright Access: Dynamic Groups and Licensing

Birthright access is built once and then maintained by attributes. Each department or role gets a dynamic group; licenses and baseline resources are assigned to those groups, never to individuals.

STEP 1 **Create a department dynamic group**

1. Entra admin center › Groups › All groups › New group. Group type *Security*; name `GRP-Dept-Finance`; membership type Dynamic User.
2. Select Add dynamic query › Edit and enter the rule below. Select Validate Rules and test three known members and one non-member.
3. Save. Membership processing can take from minutes to several hours in large tenants; check Dynamic membership processing status on the group overview.

DYNAMIC MEMBERSHIP RULES — RULE

```
# Department birthright group (enabled employees only)
(user.department -eq "Finance") -and (user.accountEnabled -eq true) -and (user.employeeType -eq "Employee")

# All active employees (used for the base license)
(user.employeeId -ne null) -and (user.accountEnabled -eq true) -and (user.employeeType -in
["Employee","Intern"])

# Contractors: separate group, separate license, separate Conditional Access scope
(user.employeeType -eq "Contractor") -and (user.accountEnabled -eq true)
```

WHY · WHY EVERY RULE TESTS ACCOUNTENABLED

Including `accountEnabled -eq true` means a disabled leaver drops out of every birthright group at the next evaluation, which removes group-based licenses and site access without anyone touching the account. It turns the leaver's first step (disable) into most of the access removal.

STEP 2 **Assign licenses to the group**

1. Entra admin center › Identity › Billing › Licenses › All products › select *Microsoft 365 E3* › Assign.

2. Add `GRP-AllEmployees`. Under **Assignment options** turn off service plans the organization does not use (for example *Sway*).
3. Check **Licensed groups** › the group › no users in *Error* state. Common errors: *usage location* missing, conflicting service plans.
4. Remove any direct license assignments for users now covered by the group, so the group is the only source.

WATCH OUT · USAGE LOCATION MUST BE SET

Group-based licensing fails silently for users without `usageLocation`. Map it from HR country in the provisioning attribute mappings, or set a default in the group's license settings, before the first joiner arrives.

CHAPTER 4

Method A · Joiner, Mover and Leaver by Hand

Manual steps for small tenants and exceptions. Even when Lifecycle Workflows do the work, every administrator should be able to run these steps from memory, because the urgent leaver is always manual.

4.1 Joiner

STEP 1 **Prepare a new starter**

1. Confirm the ServiceNow *New hire* item references an HR record. If the HR feed already created the account, verify attributes only; do not create a second account.
2. Entra admin center › **Users** › the user › **Properties**: check `employeeId`, `department`, `jobTitle`, `manager`, `usageLocation`, `employeeHireDate`.
3. Open **Groups** on the user: the department and *All employees* dynamic groups should list the user once rules have processed.
4. Open **Licenses**: the license shows *Inherited* from the group (not *Direct*).
5. Leave the account **disabled** until the start date unless pre-hire access (for example to complete training) is approved.

STEP 2 **Issue the day-one credential**

1. On the start date, enable the account: **Users** › the user › **Edit properties** › **Settings** › tick **Account enabled**.
2. **Authentication methods** › **Add authentication method** › *Temporary Access Pass*. Lifetime 8 hours, **One-time use** **Yes**.
3. Give the pass to the manager by phone or in person. Never email it to the new starter's personal address.
4. The new starter signs in with the pass at `https://aka.ms/mysecurityinfo`, registers Microsoft Authenticator or a passkey, then signs in to Windows (Autopilot, SOP-EM-004).
5. Note in the ticket: pass issued (not its value), time, and to whom.

4.2 Mover

STEP 3 **Process a role change**

1. Confirm the HR change has flowed: `department` and `jobTitle` show the new values. If not, raise it with HR rather than editing a synced attribute.
2. Check the user's **Groups** after dynamic processing: old department group gone, new one present.
3. ID Governance › **Entitlement management** › **Access packages** › filter by user: list requested access from the old role. Ask the old manager which assignments to keep; remove the rest (*Remove access*).
4. Check **Roles and administrators** and PIM eligible assignments: role assignments never move with a job change automatically.
5. Record kept and removed access in the ticket. Movers who keep old access are the most common AC-2 audit finding.

4.3 Leaver

A leaver is processed **on the leave date and time agreed with HR**, or immediately for a termination for cause. Steps 1 to 3 happen in the same sitting; steps 4 onwards follow the timeline in Figure 5.

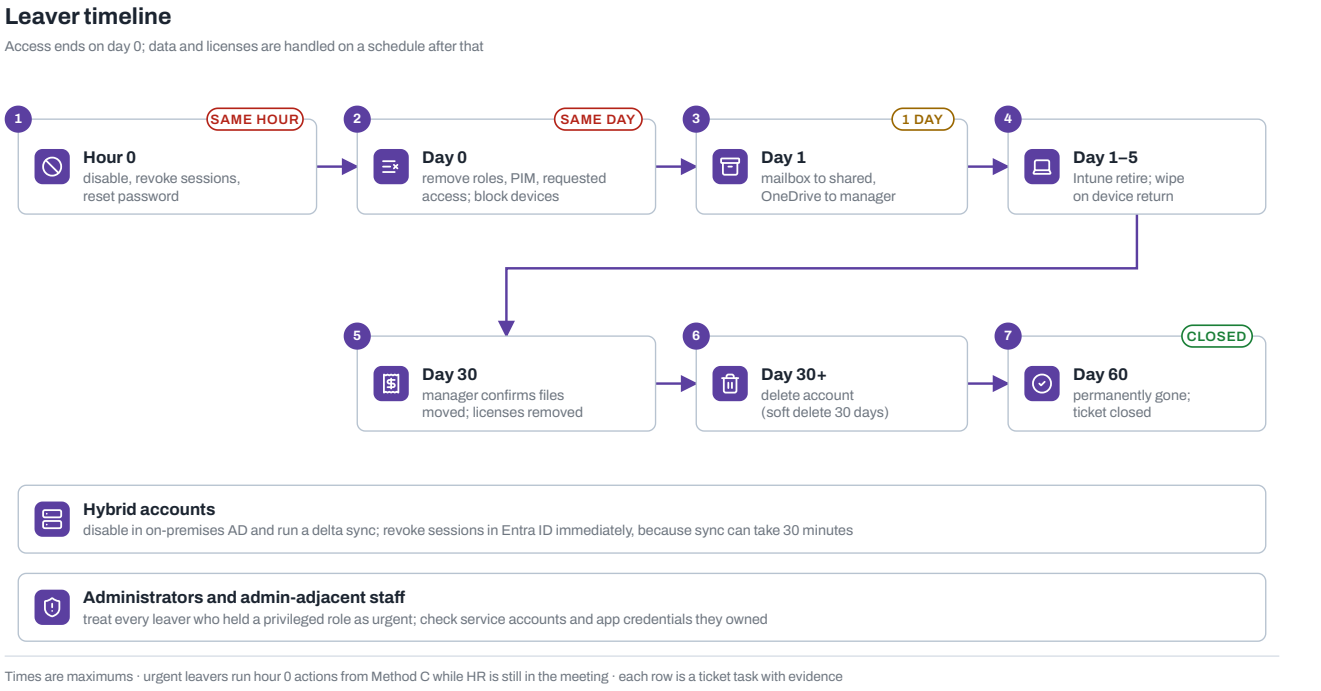


Figure 4. The leaver timeline. Access is removed first; data preservation and license reclaim follow on fixed days.

STEP 4 Hour 0 · cut access

1. **Cloud-only**: Entra admin center › `Users` › the user › `Edit properties` › `Settings` › untick `Account enabled` › `Save`. **Hybrid**: disable the account in Active Directory Users and Computers, then run a delta sync.
2. On the user overview, select `Revoke sessions` › `Yes`. This invalidates refresh tokens; apps re-check within about an hour, and Exchange / SharePoint sooner with continuous access evaluation.
3. `Reset password` to a random value that nobody records. For hybrid users, reset it in AD.
4. Note the time of each action in the ticket. The audit log is the evidence; the ticket points to it.

STEP 5 Day 0 · remove access

1. Remove `Assigned roles` (active) and PIM *eligible* assignments: ID Governance › `Privileged Identity Management` › `Microsoft Entra roles` › `Assignments` › filter by user.
2. Remove requested access: `Entitlement management` › `Access packages` › the user's assignments › `Remove access`. Birthright groups drop by themselves once the account is disabled.
3. Remove the user as owner of groups, enterprise applications and app registrations; assign a new owner first so nothing is left ownerless.
4. Intune: `Devices` › filter by user › for each corporate device, `Retire` (or wipe under multi-admin approval, SOP-EM-003). Personal BYOD devices are retired, never wiped.

STEP 6 Day 1 · preserve data

1. Exchange admin center › `Recipients` › `Mailboxes` › the user › `Others` › `Convert to shared mailbox`. Grant the manager *Full Access* if agreed with HR.
2. If the user is in scope of a legal hold: `Mailboxes` › the user › `Others` › `Manage litigation hold` › **On**, before any license is removed.
3. Microsoft 365 admin center › `Users` › `Active users` › the user › `OneDrive` › `Get access to files` › give the link to the manager. Set a reminder for day 30.
4. Set an automatic reply on the shared mailbox if the business wants one; never forward mail to a personal address.

WARNING · CONVERT BEFORE YOU UNLICENSE

Removing the Exchange license before the mailbox is converted to shared starts a 30-day countdown to mailbox deletion. Shared mailboxes up to 50 GB need no license; larger mailboxes, or those on litigation hold, keep an Exchange Online Plan 2 (or Exchange Online Archiving) license.

CHAPTER 5

Method B · Lifecycle Workflows

Lifecycle Workflows (Microsoft Entra ID Governance) run predefined tasks for users who match a scope, on a schedule relative to their hire or leave date, or when an attribute changes. They replace the scheduled parts of Method A; Method C remains for urgent leavers.

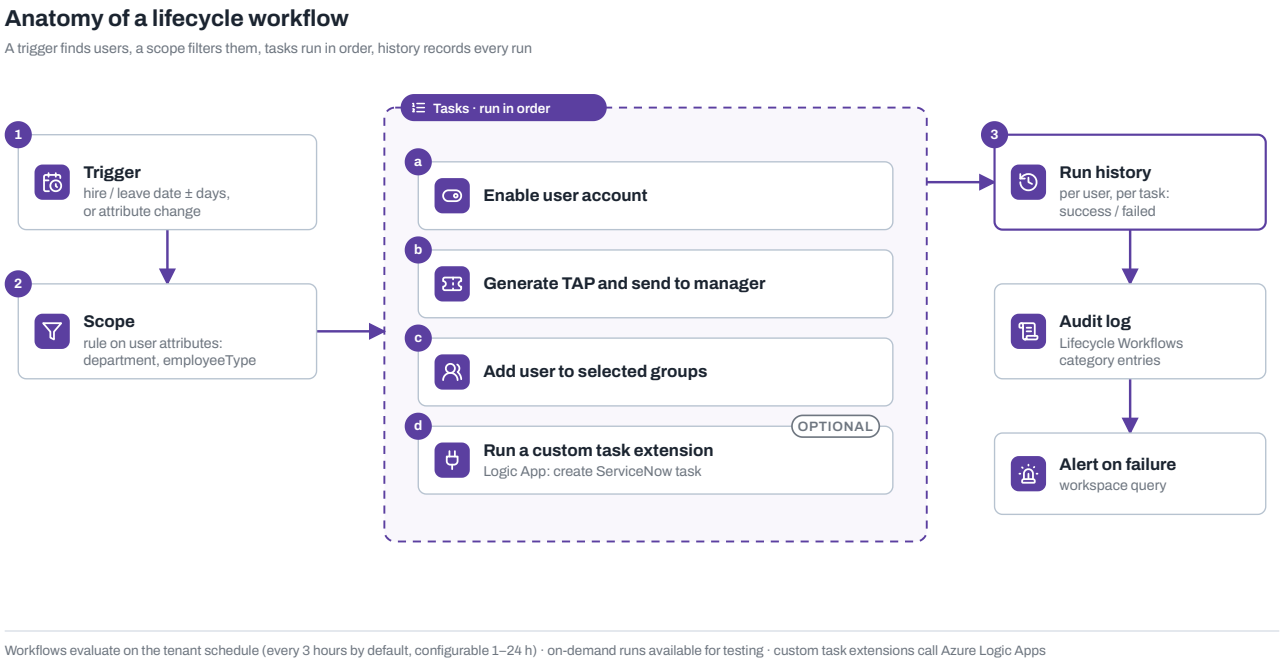


Figure 5. Every workflow has the same shape. The joiner, mover and leaver workflows below differ only in trigger and task list.

5.1 The workflow set

Workflow (template)	Trigger	Tasks
WF-J1 Pre-hire (*Onboard pre-hire employee*)	`employeeHireDate` minus 7 days	Generate TAP and send to manager (scheduled for day one) · add to onboarding group · notify manager
WF-J2 Day one (*Onboard new hire employee*)	`employeeHireDate`, 0 days	Enable user account · send welcome email · add to selected groups

Workflow (template)	Trigger	Tasks
WF-M1 Job change (*Real-time employee change*)	Attribute change: `department` or `jobTitle`	Send email to old and new manager · custom extension: create access-review task in ServiceNow
WF-L1 Last day (*Offboard an employee*)	`employeeLeaveDateTime`, 0 days	Disable user account · remove user from all groups · remove user from all Teams
WF-L2 Post-offboarding (*Post-Offboarding of an employee*)	`employeeLeaveDateTime` plus 30 days	Remove all licenses for user · delete user

NOTE · WHAT WORKFLOWS DO NOT DO

Workflows do not convert mailboxes, grant OneDrive access, retire devices or remove PIM eligibility. Cover those with a custom task extension (Logic App calling Exchange Online and Graph) or keep them as ticket tasks for the service desk on day 1.

STEP 1 Create the day-one joiner workflow

1. Entra admin center › **ID Governance** › **Lifecycle workflows** › **Create workflow** › template *Onboard new hire employee* › **Select**.
2. **Basics**: name `WF-J2-DayOne`; trigger type *Time based attribute*; days from event **0**; event user attribute **employeeHireDate**.
3. **Configure scope**: rule `(employeeType eq 'Employee') and (companyName eq 'Contoso')`. Avoid an empty scope: it means every user.
4. **Review tasks**: keep *Enable User Account*, *Send Welcome Email*; add *Add user to groups* if a group is not dynamic.
5. Leave **Enable schedule** **off**. **Create**.
6. Open the workflow › **Run on demand** › select one test user › confirm in **Workflow history** that every task shows *Completed*.
7. Turn the schedule on. Repeat for WF-J1, WF-M1, WF-L1 and WF-L2.

5.2 Graph PowerShell for workflow evidence

LIST WORKFLOW RUNS AND FAILED TASKS FOR THE LAST 7 DAYS — POWERSHELL

```powershell
Connect-MgGraph -Scopes "LifecycleWorkflows.Read.All" -NoWelcome
$since = (Get-Date).AddDays(-7).ToString("o")
Get-MgIdentityGovernanceLifecycleWorkflow -All | ForEach-Object {
  $wf = $_
  Get-MgIdentityGovernanceLifecycleWorkflowUserProcessingResult -WorkflowId $wf.Id -All |
    Where-Object { $_.CompletedDateTime -ge $since } |
    Select-Object @{n='Workflow';e={$wf.DisplayName}},
                  @{n='User';e={$_.Subject.Id}}, ProcessingStatus, FailedTasksCount, CompletedDateTime
} | Export-Csv .\lcw-runs-7d.csv -NoTypeInformation
```

CHAPTER 6

Method C · Graph PowerShell for Urgent Leavers and Reviews

The urgent leaver script runs the hour 0 and day 0 actions in one pass, writes a transcript for the ticket, and stops at anything that needs a human decision (mailbox, devices). Run it with PIM-activated roles; never from a shared account.

6.1 Urgent leaver

CONNECT AND IDENTIFY THE USER — POWERSHELL

```
Start-Transcript -Path ".\leaver-$(Get-Date -Format yyyyMMdd-HHmm).log"
Connect-MgGraph -Scopes "User.ReadWrite.All","Directory.ReadWrite.All","GroupMember.ReadWrite.All",
                        "RoleManagement.ReadWrite.Directory","User-LifeCycleInfo.ReadWrite.All" -NoWelcome
$upn  = "jordan.lee@contoso.com"           # from the HR termination record
$user = Get-MgUser -UserId $upn -Property Id,DisplayName,OnPremisesSyncEnabled,EmployeeId,AccountEnabled
$user | Format-List DisplayName, EmployeeId, OnPremisesSyncEnabled, AccountEnabled
```

HOUR 0 · DISABLE, REVOKE, RECORD THE LEAVE DATE — POWERSHELL

```
if ($user.OnPremisesSyncEnabled) {
  Write-Warning "Hybrid account: disable in AD now (Disable-ADAccount) and run Start-ADSyncSyncCycle -
PolicyType Delta"
} else {
  Update-MgUser -UserId $user.Id -AccountEnabled:$false
}
Revoke-MgUserSignInSession -UserId $user.Id            # invalidates refresh tokens
Update-MgUser -UserId $user.Id -EmployeeLeaveDateTime (Get-Date).ToUniversalTime()   # lets WF-L2 run on day 30
```

DAY 0 · REMOVE DIRECTORY ROLES, PIM ELIGIBILITY AND GROUP MEMBERSHIPS POWERSHELL

```powershell
# Active role assignments
Get-MgRoleManagementDirectoryRoleAssignment -Filter "principalId eq '$($user.Id)'" |
  ForEach-Object { Remove-MgRoleManagementDirectoryRoleAssignment -UnifiedRoleAssignmentId $_.Id }

# PIM eligible assignments: request removal through the schedule API
Get-MgRoleManagementDirectoryRoleEligibilitySchedule -Filter "principalId eq '$($user.Id)'" | ForEach-Object {
  New-MgRoleManagementDirectoryRoleEligibilityScheduleRequest -BodyParameter @{
    action = "adminRemove"; principalId = $user.Id; roleDefinitionId = $_.RoleDefinitionId
    directoryScopeId = $_.DirectoryScopeId; justification = "Leaver - ticket RITM0012345" }
}

# Assigned (non-dynamic) cloud groups; dynamic and synced groups are skipped
Get-MgUserMemberOf -UserId $user.Id -All | Where-Object { $_.'@odata.type' -eq '#microsoft.graph.group' } |
  ForEach-Object {
    $g = Get-MgGroup -GroupId $_.Id -Property Id,DisplayName,GroupTypes,OnPremisesSyncEnabled
    if ($g.GroupTypes -notcontains 'DynamicMembership' -and -not $g.OnPremisesSyncEnabled) {
      Remove-MgGroupMemberByRef -GroupId $g.Id -DirectoryObjectId $user.Id
      "Removed from $($g.DisplayName)"
    }
  }
Stop-Transcript
```

DAY 1 · MAILBOX (EXCHANGE ONLINE POWERSHELL) POWERSHELL

```powershell
Connect-ExchangeOnline
Set-Mailbox -Identity $upn -Type Shared
Add-MailboxPermission -Identity $upn -User "manager@contoso.com" -AccessRights FullAccess -AutoMapping $false
# Only if in scope of a legal hold, and before any license removal:
Set-Mailbox -Identity $upn -LitigationHoldEnabled $true -LitigationHoldDuration Unlimited
```

WATCH OUT · MAIL-ENABLED AND DISTRIBUTION GROUPS

Graph cannot change membership of mail-enabled security groups or distribution lists. Remove those in Exchange Online (`Remove-DistributionGroupMember`) or, for synced groups, in on-premises AD.

6.2 Quarterly stale and orphaned account review

The review finds accounts that the lifecycle missed: enabled accounts with no recent sign-in, enabled accounts with no `employeeId` (no HR record), and accounts whose HR record shows a leave date in the past. Every finding is either justified by an owner or disabled.

ENABLED ACCOUNTS WITH NO SIGN-IN FOR 90 DAYS, OR NO HR LINK — POWERSHELL

```powershell
Connect-MgGraph -Scopes "User.Read.All","AuditLog.Read.All" -NoWelcome
$cutoff = (Get-Date).AddDays(-90)
Get-MgUser -All -Filter "accountEnabled eq true and userType eq 'Member'" `
  -Property DisplayName,UserPrincipalName,EmployeeId,EmployeeLeaveDateTime,CreatedDateTime,SignInActivity |
  ForEach-Object {
    $last = $_.SignInActivity.LastSuccessfulSignInDateTime
    [pscustomobject]@{
      UPN        = $_.UserPrincipalName
      EmployeeId = $_.EmployeeId
      LastSignIn = $last
      Created    = $_.CreatedDateTime
      LeaveDate  = $_.EmployeeLeaveDateTime
      Finding    = if (-not $_.EmployeeId) {'No HR record'}
                   elseif ($_.EmployeeLeaveDateTime -and $_.EmployeeLeaveDateTime -lt (Get-Date)) {'Past leave
date'}
                   elseif (-not $last -or $last -lt $cutoff) {'Stale 90d'} else {$null}
    }
  } | Where-Object Finding | Export-Csv ".\stale-review-$(Get-Date -Format yyyyMMdd).csv" -NoTypeInformation
```

NOTE · SIGNINACTIVITY DETAILS

`signInActivity` needs Entra ID P1 and the `AuditLog.Read.All` permission. `lastSuccessfulSignInDateTime` is the best single indicator; `lastNonInteractiveSignInDateTime` shows token refreshes by apps. Accounts created in the last 30 days are normally excluded from the stale finding.

AUDIT LOG: LEAVER ACTIONS FOR THE EVIDENCE PACK — KQL

```kql
AuditLogs
| where TimeGenerated > ago(90d)
| where OperationName in ("Disable account","Update user","Delete user","Restore user",
                          "Remove member from group","Remove member from role")
    or OperationName has "refresh tokens"
| extend Target = tostring(TargetResources[0].userPrincipalName),
         Actor  = tostring(InitiatedBy.user.userPrincipalName)
| project TimeGenerated, OperationName, Target, Actor, Result
| order by Target asc, TimeGenerated asc
```

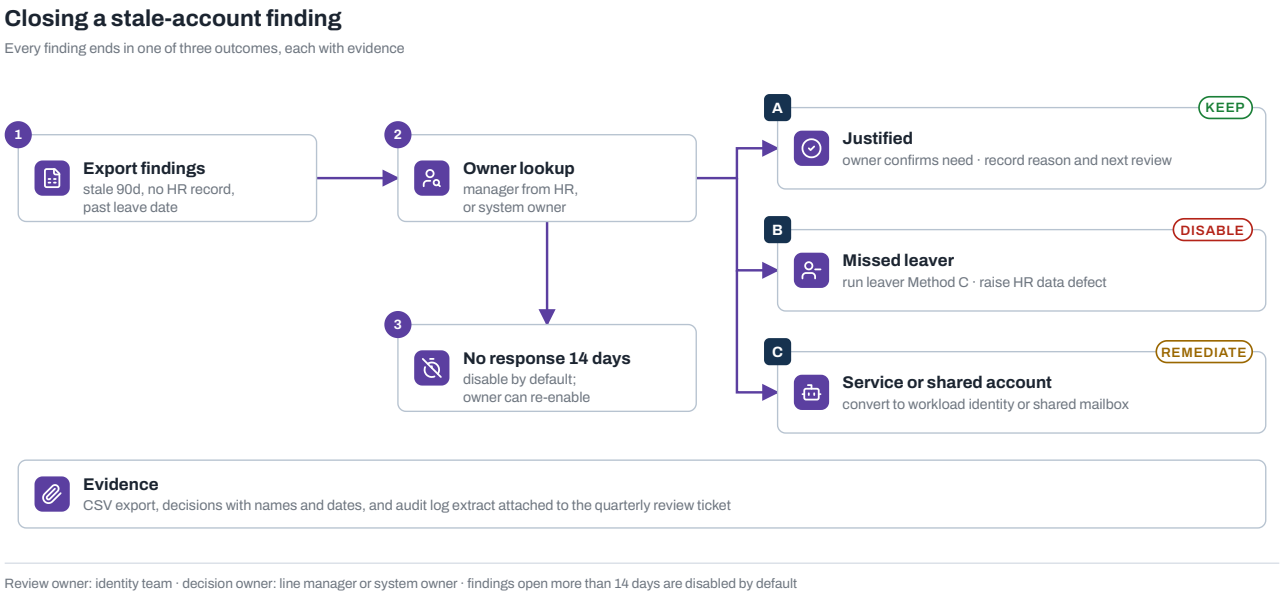


Figure 6. The quarterly review. A finding is never closed without an owner decision or a disable action.

CHAPTER 7

Verification, Rollback and Troubleshooting

7.1 Verification checklist

Check	How	Expected
Joiner attributes	User properties or `Get-MgUser -Property employeeId,department,manager,usageLocation`	All populated from HR; no blanks
Birthright groups	User › Groups	Department and *All employees* dynamic groups present
License source	User › Licenses	*Inherited* from group; no *Direct* assignments
Leaver disabled	User overview	*Account enabled: No*; for hybrid, AD disabled and synced
Sessions revoked	Audit log, activity *Invalidate all refresh tokens for user* (or equivalent)	Entry within the hour 0 window
No roles or eligibility	PIM › Assignments filtered by user	None active, none eligible
Mailbox preserved	`Get-Mailbox $upn | fl RecipientTypeDetails,LitigationHoldEnabled`	*SharedMailbox*; hold as decided
Devices retired	Intune › Devices filtered by user	None compliant and active
Workflow health	Lifecycle workflows › Workflow history	No failed tasks in the last 7 days

7.2 Rollback

Situation	Action	Notes
Wrong person disabled	Re-enable account (AD for hybrid); re-add requested access from the ticket; the user re-registers if sessions were revoked	Birthright groups and licenses return automatically once enabled
Account deleted too early	Entra admin center › **Users** › **Deleted users** › select › **Restore user**; or `Restore-MgDirectoryDeletedItem -DirectoryObjectId <id>`	Within 30 days only; group memberships and licenses are restored with the object
Leave date changed by HR	Update `employeeLeaveDateTime`; if WF-L1 already ran, re-enable and restore access as above	Record HR's confirmation in the ticket
Dynamic rule removed a department	Revert the rule text from the change record; select **Pause processing** while fixing	Licenses removed by a rule error are re-applied when membership returns

7.3 Troubleshooting

Symptom	Likely cause	Fix
Leaver still reading mail on a phone after disable	Refresh token still valid; sessions not revoked	Revoke sessions; for Exchange / SharePoint, continuous access evaluation applies within minutes once revoked
Hybrid leaver re-enabled after a few minutes	Account disabled in Entra ID but still enabled in AD; sync overwrote it	Disable in AD, then delta sync
Lifecycle workflow never ran for a user	`employeeLeaveDateTime` / `employeeHireDate` empty, or user outside scope rule	Check attributes; test with **Run on demand**; widen or fix the scope rule
New starter has no license on day one	`usageLocation` blank, or group license in error	Set usage location via HR mapping; check **Licensed groups** errors
Mover still has old department site	Site access granted directly or via a non-dynamic group	Grant site access only through birthright groups or access packages
Manager cannot open leaver's OneDrive	Manager attribute empty, or OneDrive deleted after retention	Assign access as SharePoint admin; increase OneDrive retention
Temporary Access Pass rejected	Pass expired, already used, or TAP not enabled for the user	Issue a new pass; check the Authentication methods policy target group

CHAPTER 8

Summary, Glossary and Review

8.1 Chapter summary

- HR is the source of truth; attributes from HR trigger every joiner, mover and leaver action.
- Birthright access comes from dynamic groups and group-based licensing; requested access comes from access packages with approval and expiry.
- Joiners get a disabled pre-hire account, then a one-time Temporary Access Pass delivered to the manager on day one.
- Movers lose old requested access deliberately; role assignments never move automatically.
- Leavers are disabled and revoked in the same hour; data is preserved on day 1; licenses are reclaimed and the account deleted from day 30.
- Lifecycle Workflows automate the scheduled cases; the Graph script handles urgent leavers; the quarterly review catches what both missed.

Check your understanding

1. Why does every dynamic birthright rule in this SOP include `user.accountEnabled -eq true`?
2. A hybrid leaver was disabled in the Entra admin center but signs in again an hour later. What happened and what is the fix?
3. In what order must the mailbox conversion and license removal happen, and why?
4. Which attribute must be set for WF-L2 to run, and which permission is needed to write it?
5. Name the three outcomes for a stale-account finding and the evidence each requires.

8.2 Glossary

JML	Joiner-Mover-Leaver: the three lifecycle events at which access must change.
Inbound provisioning	Entra service that creates and updates users from an HR system or the provisioning API.
Birthright access	Access granted automatically by attributes, with no request.
Access package	Bundle of groups, apps, sites and roles requested through entitlement management, with approval and expiry.
Lifecycle Workflows	Entra ID Governance feature that runs tasks for users based on hire date, leave date or attribute changes.
Temporary Access Pass	Time-limited passcode that satisfies MFA so a user can register strong methods.
Revoke sessions	Invalidates a user's refresh tokens and session cookies so apps must re-authenticate.

signInActivity	Graph user property holding the last interactive, non-interactive and successful sign-in times.
Soft delete	Deleted users stay restorable for 30 days before permanent removal.

8.3 Framework references

Framework	Controls addressed
NIST SP 800-53 Rev. 5	AC-2 Account Management · AC-2(3) Disable Accounts · AC-2(4) Automated Audit Actions · AC-6 Least Privilege · PS-4 Personnel Termination · PS-5 Personnel Transfer
SOX IT general controls	Logical access: user provisioning, timely termination, periodic access review
FDA 21 CFR Part 11	§11.10(d) limiting system access to authorized individuals · §11.300(b) periodic checking of identification codes
ISO/IEC 27001:2022	Annex A 5.16 Identity management · 5.18 Access rights · 6.5 Responsibilities after termination or change of employment